

VirtuEx 시스템 감사 보고서 (11차)

VirtuEx System Audit Report (11th)

- 감사일: 2026-03-10
- 감사 범위: 전체 프로젝트 (백엔드 8개 마이크로서비스 + 프론트엔드)
- 감사 방법: 전체 소스 코드 정적 분석 + 브라우저 기반 기능 테스트
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)

요약 (Executive Summary)

이전 10차 감사 대비 발견된 이슈가 크게 증가한 이유는 이번 감사에서 전체 코드를 파일 단위로 정밀 분석했기 때문입니다. 특히 데이터 정합성(가격, 잔고, 주문 상태)과 보안(인증, 입력 검증, 세션 관리) 영역에서 집중 감사를 수행했습니다.

1. 주문 엔진 (Order Engine) — 4건

[C-01] 주문 체결 완료(FILLED) 상태 전이 실패 (Critical)

- 파일: order-engine/src/domain/aggregates/order.aggregate.ts:99
- 설명: match() 메서드에서 ORDER_FILLED 이벤트 발행 조건이 this._remainingQuantity.isZero()를 검사하지만, 이 검사는 잔량이 차감되기 전에 실행됩니다. onMatched 핸들러에서 잔량이 업데이트되므로, 이 조건은 절대로 true가 되지 않습니다.
- 영향: 주문이 완전 체결되어도 FILLED 상태로 전이되지 않고 PARTIAL 상태로 유지되어, 주문 생명주기가 정상 종료되지 않습니다.
- 수정: this._remainingQuantity.minus(matchQty).isZero() 조건으로 변경하거나, onMatched() 핸들러 내부에서 FILLED 이벤트를 발행합니다.

[C-02] 수량 0인 주문 허용 (Critical)

- 파일: order-engine/src/presentation/dto/place-order.dto.ts:36
- 설명: 주문 수량 검증 정규식 ^\d+(\.\d+)?\$ 이 "0" 또는 "0.00"을 유효한 값으로 통과시킵니다. 수량 0 주문이 매칭 엔진에 도달하면 0으로 나누기 오류가 발생할 수 있습니다.
- 수정: @Min(0.00000001) 데코레이터 추가 또는 서비스 레이어에서 0 수량 검증.

[H-01] 자기 거래(Self-Trading) 미방지 (High)

- 파일: `order-engine/src/domain/services/matching-engine.service.ts:172-253`
- 설명: 매칭 엔진이 주문을 매칭할 때 주문자와 상대방의 `userId`를 비교하지 않습니다. 동일 사용자의 매수/매도 주문이 서로 체결될 수 있습니다.
- 영향: 거래량 조작, 가격 조종, 포트폴리오 왜곡 가능.
- 수정: 매칭 루프에서 `if (entry.userId === userId) continue;` 추가.

[H-02] 음수 가격 주문 허용 (High)

- 파일: `order-engine/src/presentation/dto/place-order.dto.ts:31`
- 설명: 정규식 검증은 양수만 허용하지만, `@Min()` 데코레이터가 없어 API 레벨에서 음수 가격이 직접 전달될 수 있습니다.
- 수정: `@Min(0.00000001)` 데코레이터 추가.

2. 포트폴리오 서비스 (Portfolio) — 5건

[C-03] 리더보드 PnL 계산 오류 (Critical)

- 파일: `portfolio/src/domain/services/balance.service.ts:880-889`
- 설명: `txNetDeposit <= 0` 일 때 순입금액을 `totalValue - totalPnl` 로 역산합니다. 입금 내역이 없는 사용자의 경우 PnL%가 왜곡되거나 음수로 표시됩니다.
- 영향: 리더보드 순위가 부정확하게 산출됩니다.
- 수정: 순입금액이 0인 경우 PnL%를 0으로 처리하거나, 실현 손익만으로 순위를 산출합니다.

[H-03] 부분 매도 시 취득원가 배분 정밀도 손실 (High)

- 파일: `portfolio/src/domain/services/balance.service.ts:559`
- 설명: `costReduction = existingTotalCost × qty / existingQty` 계산에서 Decimal.js의 `toFixed(8)` 반올림으로 인해 반복적인 부분 매도 시 누적 오차가 발생합니다.
- 영향: 활발한 거래자의 실현 손익이 장기적으로 부정확해집니다.
- 수정: FIFO 방식의 원가 배분 또는 마지막 매도 시 잔여 원가 전액 차감 방식 적용.

[H-04] 자금 해제 실패 시 재시도 없음 (High)

- 파일: `portfolio/src/domain/services/balance.service.ts:333-388`
- 설명: `releaseFunds()` 메서드가 실패 시 에러를 로깅만 하고 재시도하지 않습니다. 주문 취소/실패 후 예약된 자금이 영구적으로 잠길 수 있습니다.

- 수정: 지수 백오프 재시도 또는 별도의 자금 해제 작업 큐 구현.

[M-01] 카피 트레이딩 순환 참조 미방지 (Medium)

- 파일: `portfolio/src/domain/services/copy-trade.service.ts:66-68`
- 설명: 직접적인 자기 복사($A \rightarrow A$)는 방지하지만, $A \rightarrow B \rightarrow A$ 순환 체인은 검증하지 않습니다.
- 수정: 카피 설정 시 BFS/DFS 그래프 순환 탐지 추가.

[M-02] 카피 트레이딩 투자한도 초과 가능 (Medium)

- 파일: `portfolio/src/domain/services/copy-trade.service.ts:337`
- 설명: `totalInvested` 업데이트 시 반올림으로 인해 `maxInvestment` 한도를 미세하게 초과할 수 있습니다.
- 수정: 업데이트 후 `totalInvested <= maxInvestment` 명시적 검증 추가.

3. 시장 데이터 서비스 (Market Data) — 7건

[C-04] 캔들스틱 고가/저가 레이스 컨디션 (Critical)

- 파일: `market-data/src/application/services/market-data.service.ts:406-431`
- 설명: 캔들 upsert 시 `highPrice` / `lowPrice` 를 현재 틱 가격으로 초기화한 후, 별도 SQL로 원자적 max/min 업데이트를 수행합니다. 두 연산 사이에 다른 틱이 처리되면 고가/저가가 부정확해집니다.
- 수정: 단일 원자적 쿼리로 upsert + 조건부 max/min 업데이트 통합.

[C-05] Binance 가격 캐시 메모리 누수 (Critical)

- 파일: `market-data/src/domain/services/binance-price.service.ts:20, 132`
- 설명: `cache` Map이 항목을 추가만 하고 제거하지 않습니다. 약 100개 심볼 x 초당 1+틱으로 무한히 증가합니다 (실질적으로는 심볼당 1개만 유지되므로 제한적이나, 코드 구조상 잠재적 위험).
- 수정: 심볼 키 기반이므로 실제 무한 증가는 아니지만, stale 데이터 정리 타이머 추가 권장.

[H-05] Binance kline 파싱 시 부동소수점 정밀도 손실 (High)

- 파일: `market-data/src/application/services/market-data.service.ts:295-304`
- 설명: Binance API의 문자열 가격을 `parseFloat()` 로 변환 시 소수점 이하 극소 가격 (예: PEPE \$0.0000012)에서 정밀도가 손실됩니다.
- 수정: 가격 파싱에 `Decimal.js` 또는 `BigNumber` 라이브러리 사용.

[H-06] 기간별 등락 데이터 누락 가능 (High)

- 파일: `market-data/src/application/services/market-data.service.ts:235-249`
- 설명: 암호화폐 자산에서 Binance 과거 가격이 없으면 해당 심볼의 기간별 등락 데이터가 응답에서 누락됩니다.
- 영향: 프론트엔드가 요청한 종목 수와 응답 종목 수 불일치.
- 수정: Binance 데이터 미존재 시 시뮬레이션 데이터로 폴백.

[H-07] Decimal 오버플로 무경고 절삭 (High)

- 파일: `market-data/src/application/services/market-data.service.ts:367-392`
- 설명: `clampDecimal()` 메서드가 $\pm 999,999,999,999$ 범위로 절삭하지만 경고 로그를 남기지 않습니다.
- 수정: 절삭 발생 시 WARN 레벨 로깅 추가.

[M-03] GBM 시뮬레이션 Drift 기본값 0 (Medium)

- 파일: `market-data/src/domain/services/price-engine.service.ts:42, 51`
- 설명: 기하 브라운 운동(GBM) 시뮬레이션의 drift 파라미터가 기본 0.0으로, 장기 가격 추이가 랜덤 워크됩니다.
- 수정: 현실적인 소폭 양의 drift 적용 또는 시뮬레이션 표시 명시.

[M-04] 거래량 스파이크 상한 없음 (Medium)

- 파일: `market-data/src/domain/services/price-engine.service.ts:132-139`
- 설명: 가격 변동폭에 비례한 거래량 계산에서 상한이 없어, 큰 가격 변동 시 비현실적인 거래량 급등이 발생합니다.
- 수정: `movementFactor` 를 최대 5x로 제한: `Math.min(movementFactor, 5)`.

4. 사용자 인증 서비스 (User Auth) — 12건

[C-06] 회원가입 시 중복 검사와 생성의 비원자성 (Critical)

- 파일: `user-auth/src/application/services/auth.service.ts:78-91`
- 설명: 이메일/유저명/전화번호 중복 검사와 사용자 생성이 트랜잭션으로 묶여있지 않습니다. 동시 요청 시 동일 이메일로 중복 가입이 발생할 수 있습니다.
- 수정: Prisma 트랜잭션으로 중복 검사 + 생성을 원자적으로 처리하거나, DB unique constraint 에러를 적절히 핸들링.

[C-07] 주민등록번호 암호화에 JWT_SECRET 사용 (Critical)

- 파일: `user-auth/src/application/services/auth.service.ts:100-102`
- 설명: RRN 암호화 키로 JWT 서명용 비밀키(JWT_SECRET)를 사용합니다. JWT_SECRET 로테이션 시 모든 암호화된 RRN이 복호화 불가능해집니다.
- 수정: 전용 ENCRYPTION_KEY 사용 + 키 버저닝 지원.

[H-08] SMS 인증 요청 무제한 (High)

- 파일: `user-auth/src/presentation/controllers/auth.controller.ts:199-213`
- 설명: SMS 전송/검증 엔드포인트에 IP 기반 또는 전화번호 기반 요청 제한이 없습니다.
- 수정: Redis 기반 레이트 리미팅 미들웨어 추가.

[H-09] Refresh Token 갱신 비원자성 (High)

- 파일: `user-auth/src/application/services/auth.service.ts:319-367`
- 설명: 토큰 리프레시 시 기존 토큰 삭제와 새 토큰 생성이 별도 연산입니다. 생성 실패 시 사용자가 예기치 않게 로그아웃됩니다.
- 수정: Prisma 트랜잭션으로 삭제와 생성을 원자적으로 처리.

[H-10] 사용자 삭제 시 관련 데이터 미정리 (High)

- 파일: `user-auth/src/application/services/admin.service.ts:279`
- 설명: 사용자 삭제 시 알림, 팔로우, 커뮤니티 게시글/댓글/좋아요, 가격 알림 등 관련 데이터가 정리되지 않습니다.
- 수정: Prisma 스키마에 cascade delete 설정 또는 수동 정리 로직 추가.

[H-11] Redis 명령 타임아웃 미설정 (High)

- 파일: `user-auth/src/infrastructure/redis/redis.module.ts:20-25`
- 설명: Redis 클라이언트에 `commandTimeout` 이 설정되지 않아 Redis 행 시 요청이 무한 대기합니다.
- 수정: `commandTimeout: 5000` 설정 추가.

[M-05] 커뮤니티 게시글 visibility 검증 누락 (Medium)

- 파일: `user-auth/src/presentation/controllers/community.controller.ts:214`
- 설명: visibility 필드가 DTO에서 enum 검증 없이 직접 저장됩니다.
- 수정: `@IsEnum(['PUBLIC', 'MEMBERS_ONLY'])` 데코레이터 추가.

[M-06] 관리자 상세 조회 N+1 쿼리 (Medium)

- 파일: `user-auth/src/application/services/admin.service.ts:140-155`
- 설명: `getUserDetail()` 이 사용자 조회 후 승인자/반려자 이름을 별도 쿼리로 조회합니다.
- 수정: Prisma `include` 로 단일 쿼리로 통합.

[M-07] Redis 세션 JSON 파싱 미검증 (Medium)

- 파일: `user-auth/src/application/services/auth.service.ts:222, 248, 470`
- 설명: Redis에서 읽은 세션 데이터를 `JSON.parse()` 시 try-catch 없이 처리합니다.
- 수정: JSON 파싱에 try-catch 추가 및 구조 검증.

[M-08] 레거시 RRN 암호화 하드코딩 솔트 (Medium)

- 파일: `user-auth/src/domain/value-objects/resident-number.vo.ts:66`
- 설명: 레거시 데이터 복호화용으로 'virtuex-salt' 문자열이 소스에 하드코딩되어 있습니다.
- 수정: 레거시 데이터 마이그레이션 후 제거.

[L-01] 백엔드 오류 메시지 한국어 단일 언어 (Low)

- 파일: `auth.service.ts, admin.service.ts` 등 다수
- 설명: 에러 메시지가 한국어로만 작성되어 있어 비한국어 사용자에게 불편합니다.
- 수정: 에러 코드 기반 응답으로 변경하여 프론트엔드에서 i18n 처리.

[L-02] 팔로워 목록 서비스 레이어 상한 미설정 (Low)

- 파일: `user-auth/src/application/services/follow.service.ts:76-109`
- 설명: 컨트롤러에서 limit을 제한하지만 서비스 레이어에서는 상한이 없습니다.
- 수정: `Math.min(limit, 100)` 추가.

5. API 게이트웨이 (API Gateway) — 8건

[C-08] JWT 검증 시 user-auth 장애로 전체 인증 실패 (Critical)

- 파일: `api-gateway/src/auth/jwt.strategy.ts:47-61`

- **설명:** JWT 검증 과정에서 user-auth 서비스의 사용자 상태 확인이 실패하면 모든 인증이 거부됩니다. user-auth 서비스 장애 시 전체 플랫폼 사용 불가(DoS).
- **수정:** 서킷 브레이커 패턴 적용 또는 Redis 캐시 기반 풀백으로 최근 검증된 사용자 허용.

[H-12] Set-Cookie 헤더 무검증 전달 (High)

- **파일:** `api-gateway/src/proxy/auth-proxy.controller.ts:113-115`
- **설명:** 다운스트림 서비스의 Set-Cookie 헤더를 검증 없이 클라이언트에 전달합니다.
- **수정:** 쿠키 도메인, Secure/HttpOnly 플래그 검증 후 전달.

[H-13] 채팅 게이트웨이 메시지 길이 검증 우회 (High)

- **파일:** `api-gateway/src/gateway/chat.gateway.ts:46-63`
- **설명:** 미들웨어에서 메시지 길이 초과 시 에러를 emit하지만 핸들러 실행을 차단하지 않습니다.
- **수정:** 에러 emit 후 `return` 대신 실제 핸들러 실행을 차단하는 구조로 변경.

[H-14] 리더보드 데이터 보강 타임아웃 없음 (High)

- **파일:** `api-gateway/src/proxy/portfolio-proxy.controller.ts:176-209`
- **설명:** 리더보드에서 사용자 이름 보강 호출에 타임아웃이 없어 user-auth 응답 지연 시 전체 응답이 지연됩니다.
- **수정:** 보강 호출에 2초 타임아웃 + 타임아웃 시 이름 없이 응답하는 풀백.

[M-09] 가격 알림 갱신 무경고 실패 (Medium)

- **파일:** `api-gateway/src/gateway/price-subscriber.service.ts:73-75`
- **설명:** `refreshAlerts()` 실패 시 WARN만 로깅하고 재시도하지 않습니다. 영구 실패 시 가격 알림이 작동하지 않습니다.
- **수정:** 연속 실패 카운터 + 지수 백오프 재시도 추가.

[M-10] WebSocket 구독 요청 무제한 (Medium)

- **파일:** `api-gateway/src/gateway/price.gateway.ts:109-143`
- **설명:** 인증된 사용자의 구독 요청에 초당 횟수 제한이 없어 리소스 소진 공격이 가능합니다.
- **수정:** 소켓당 초당 최대 10회 구독 제한 추가.

[M-11] 프록시 에러 응답에 내부 서비스명 노출 (Medium)

- **파일:** `api-gateway/src/proxy/proxy.service.ts:125, 130`

- **설명:** 클라이언트 에러 응답에 내부 서비스 이름이 포함됩니다.
- **수정:** 클라이언트에는 일반적인 에러 메시지, 내부 로그에만 상세 정보.

[L-03] Redis 재연결 전략 미설정 (Low)

- **파일:** `api-gateway/src/redis/redis.module.ts:17`
- **설명:** Redis 장애 복구 후 자동 재연결 전략이 미설정입니다.
- **수정:** `enableReadyCheck: true` 설정 추가.

6. 알림/AI 서비스 (Notification / AI Service) — 4건

[C-09] InternalAuthGuard 타이밍 공격 취약점 (Critical)

- **파일:** `notification/src/email/email.controller.ts:57-59`
- **설명:** `timingSafeEqual` 호출 전 토큰 길이를 비교하여 올바른 토큰 길이를 유추할 수 있습니다.
- **수정:** 길이가 다를 경우에도 `timingSafeEqual` 을 사용하도록 버퍼를 동일 길이로 패딩.

[M-12] AI 분석 0으로 나누기 위험 (Medium)

- **파일:** `ai-service/src/analysis/analysis.service.ts:129`
- **설명:** `totalValue` 가 0일 때 `h.value / totalValue` 로 NaN이 발생합니다.
- **수정:** `totalValue === 0` 시 조기 반환.

[M-13] 이메일 본문 크기 제한 없음 (Medium)

- **파일:** `notification/src/email/email.controller.ts:49-65`
- **설명:** 내부 이메일 전송 API에 본문 크기 제한이 없습니다.
- **수정:** `app.useBodyParser('json', { limit: '1mb' })` 추가.

[L-04] AI 시장 신호 기준가 하드코딩 (Low)

- **파일:** `ai-service/src/analysis/analysis.service.ts:33-40`
- **설명:** 시장 신호 생성에 사용되는 기준 가격이 하드코딩되어 실제 시세와 괴리가 발생합니다.
- **수정:** 실시간 시세 데이터를 입력으로 받도록 변경.

7. 채팅 서비스 (Chat) — 3건

[M-14] 참가자 검증과 메시지 생성 비원자성 (Medium)

- 파일: chat/src/chat/chat.service.ts:632-639
- 설명: verifyParticipant() 검증과 메시지 생성이 원자적이지 않아, 검증과 생성 사이에 사용자가 강퇴되면 비참가자 메시지가 생성됩니다.
- 수정: 트랜잭션으로 검증 + 메시지 생성 통합.

[M-15] 시스템 메시지 사용자명 미이스케이프 (Medium)

- 파일: chat/src/chat/chat.service.ts:347, 373, 407
- 설명: 초대/퇴장 시스템 메시지에 사용자명이 JSON에 직접 삽입됩니다. 특수문자가 포함된 이름이 JSON을 깨뜨릴 수 있습니다.
- 수정: JSON.stringify() 가 자동 이스케이핑하므로 현재 안전하지만, XSS 방지를 위해 프론트엔드에서 textContent 로 렌더링 확인 필요.

[L-05] 채팅방 목록 N+1 쿼리 (Low)

- 파일: chat/src/chat/chat.service.ts:58-89
- 설명: 읽지 않은 메시지 수 계산이 groupBy + findMany 두 단계로 수행됩니다.
- 수정: 단일 SQL JOIN으로 최적화.

8. 프론트엔드 데이터 레이어 (Hooks / Stores / Utils) — 14건

[C-10] 채팅 메시지 캐시 동시 변경 충돌 (Critical)

- 파일: frontend/src/hooks/useChat.ts:124-136
- 설명: 메시지 전송과 삭제 뮤테이션이 pages[0].items 배열을 직접 수정합니다. 동시 실행 시 배열이 손상됩니다.
- 수정: 불변 업데이트 패턴 사용: pages.map(p => ({...p, items: [...p.items]}))

[C-11] 채팅 타이핑 맵 메모리 누수 (Critical)

- 파일: frontend/src/hooks/useChatSocket.ts:44-77
- 설명: typingMap 과 typingListeners 모듈 레벨 전역 변수가 방을 나가도 정리되지 않습니다.
- 수정: 빈 맵 항목 정리 로직 추가.

[H-15] 포트폴리오 필드 매핑 불일치 (High)

- 파일: `frontend/src/hooks/usePortfolio.ts:47-92`

- 설명: `balance.availableCash ?? balance.totalCash ?? '0'` 같은 다중 폴백이 API 응답 구조 변경에 취약합니다. `||` 연산자로 0을 falsy로 처리하는 곳도 있습니다.

- 수정: 명시적 `?? 0` 사용 및 API 응답 구조 검증 추가.

[H-16] 환율 API 응답 미검증 (High)

- 파일: `frontend/src/hooks/useExchangeRate.ts:157-215`

- 설명: 환율 API 응답에서 `rate` 가 유효한 양수인지 검증하지 않습니다. NaN이나 Infinity가 1시간 캐시됩니다.

- 영향: 모든 가격 변환이 잘못됨.

- 수정: `Number.isFinite(rate) && rate > 0` 검증 추가.

[H-17] 캔들스틱 데이터 가격=0 제거 (High)

- 파일: `frontend/src/hooks/useMarket.ts:203`

- 설명: `!open || !high || !low || !close` 검사가 가격 0을 유효하지 않은 데이터로 처리합니다. 극저가 암호화폐에서 가격 0은 유효할 수 있습니다.

- 수정: `Number.isFinite()` 검사로 변경.

[M-16] REST 폴링이 WebSocket 데이터 덮어쓰기 (Medium)

- 파일: `frontend/src/hooks/useMarket.ts:22-32`

- 설명: `refetchInterval: 30_000` 에 `staleTime` 미설정으로 REST 폴링이 WebSocket 실시간 데이터를 30초마다 덮어씁니다.

- 수정: `staleTime: 25_000` 설정으로 WebSocket 활성 시 불필요한 폴링 방지.

[M-17] 팔로우 낙관적 업데이트 ID 불일치 (Medium)

- 파일: `frontend/src/hooks/useFollow.ts:118-139`

- 설명: 낙관적 업데이트로 `optimistic-${userId}` 임시 ID를 사용하지만, 서버 응답의 실제 ID로 교체하지 않아 캐시가 불일치합니다.

- 수정: 성공 시 캐시 무효화 또는 서버 ID로 교체.

[M-18] 숫자 포매팅 Infinity 미처리 (Medium)

- 파일: `frontend/src/lib/format.ts:39-59`

- 설명: `formatPercent()` 에서 `isNaN()` 검사만 하고 `Infinity` 미검사. `.toFixed()` 호출 시 크래시.

- 수정: `Number.isFinite()` 검사 추가.

[M-19] 주문 수량 NaN 전파 (Medium)

- 파일: `frontend/src/hooks/useOrders.ts:60`
- 설명: `Number(o.quantity) || 0` 에서 `NaN || 0` 은 0이 아닌 `NaN` 을 반환합니다.
- 수정: `parseFloat()` + `Number.isFinite()` 검증.

[M-20] API 토큰 갱신 레이스 컨디션 (Medium)

- 파일: `frontend/src/lib/api.ts:30-63`
- 설명: 토큰 갱신 대기열(`failedQueue`)이 전역 공유됩니다. WebSocket 초기화 중 401 발생 시 만료된 토큰으로 대기열이 해소될 수 있습니다.
- 수정: 요청별 토큰 버전 추적 구현.

[L-06] i18n 키 명명 불일치 (Low)

- 파일: `frontend/src/lib/i18n.ts`
- 설명: `camelCase( nav.home )`, `dot-notation( auth.login.title )`, 하이브리드 형식이 혼재합니다.
- 수정: 일관된 명명 규칙(dot-notation) 표준화.

[L-07] 포트폴리오 CSV 내보내기 이스케이핑 미처리 (Low)

- 파일: `frontend/src/app/(main)/portfolio/page.tsx:314-336`
- 설명: CSV 내보내기 시 심볼에 특수문자(쉼표, 따옴표)가 포함되면 CSV가 깨집니다.
- 수정: CSV 이스케이핑 라이브러리 사용.

[L-08] 시간 표시 함수 i18n 미사용 (Low)

- 파일: `frontend/src/app/(main)/community/page.tsx:270-279`
- 설명: `timeAgo()` 함수가 하드코딩된 한/영 문자열을 사용합니다.
- 수정: `t()` 함수로 i18n 키 사용.

[L-09] 페이지네이션 ARIA 속성 누락 (Low)

- 파일: `frontend/src/components/ui/Pagination.tsx:114-160`
- 설명: 페이지 버튼에 `aria-current="page"` 및 `aria-label` 누락.

- 수정: 접근성 속성 추가.

9. 프론트엔드 페이지/컴포넌트 (Pages / Components) — 12건

[C-12] 종목 상세 시가(Open Price) 계산 오류 (Critical)

- 파일: `frontend/src/app/(main)/asset/[symbol]/page.tsx:329`
- 설명: 시가를 `currentPrice - changeAmount` 로 계산하지만, `changeAmount = currentPrice - openPrice` 이므로 정확한 시가는 `currentPrice - changeAmount` 가 맞습니다. 그러나 `changeAmount` 가 음수일 경우(하락 시) 시가가 현재가보다 낮게 표시되는 오류가 있습니다.
- 검증 필요: `changeAmount` 의 부호 규칙(양수=상승, 음수=하락)을 백엔드와 대조하여 시가 계산 정확성 확인 필요.

[H-18] 주문 폼 통화 변환 로직 오류 (High)

- 파일: `frontend/src/components/trading/OrderForm.tsx:50-65`
- 설명: `toDisplayPrice()` 와 `toUsdPrice()` 함수에서 KRW 심볼일 때 변환을 건너뛰지만, 사용자가 통화 모드를 전환해도 가격이 실제로 변환되지 않습니다.
- 수정: 통화 모드와 심볼 통화 단위의 교차 변환 로직 수정.

[H-19] 상세 페이지 지표 null 미처리 (High)

- 파일: `frontend/src/app/(main)/asset/[symbol]/page.tsx:324-369`
- 설명: 지표 그리드에서 `high24h`, `low24h`, `volume` 이 `undefined` 일 때 0으로 표시됩니다. "-" 표시가 더 정확합니다.
- 수정: `value ? fp(value) : '-'` 패턴 적용.

[H-20] 거래 분석 승률 계산 단순화 (High)

- 파일: `frontend/src/app/(main)/orders/page.tsx:147-173`
- 설명: 승률 계산이 심볼별 평균 매수가와 평균 매도가만 비교합니다. 여러 번의 매수/매도 사이클, 부분 체결, 실행 순서를 고려하지 않습니다.
- 수정: 실제 체결 순서 기반의 실현 손익 사이클 추적.

[M-21] 관리자 테이블 접근성 위반 (Medium)

- 파일: `frontend/src/app/(main)/admin/users/page.tsx:326-362`
- 설명: 테이블 행에 `role="link"` 속성이 사용되지만, 키보드 네비게이션(Enter/Space)이 미지원됩니다.

- 수정: `role="button" + tabIndex={0} + onKeyDown` 핸들러 추가.

[M-22] AssetList FLIP 애니메이션 Ref 미정리 (Medium)

- 파일: `frontend/src/components/market/AssetList.tsx:151-181`
- 설명: 행 DOM 참조가 심볼 제거 시에도 Map에서 삭제되지 않습니다.
- 수정: `paged` 변경 시 불필요한 ref 항목 정리.

[M-23] 모달 포커스 트랩 미검증 (Medium)

- 파일: 다수 모달 컴포넌트
- 설명: `useFocusTrap()` 혹은 포커스 가두기/복원 기능이 모든 모달에서 정상 동작하는지 검증이 필요합니다.
- 수정: 모든 모달에서 키보드 네비게이션 테스트 수행.

[M-24] 커뮤니티 전략 작성 자격 검증 불안정 (Medium)

- 파일: `frontend/src/app/(main)/community/page.tsx:386-402`
- 설명: 리더보드의 `isMe` 플래그에 의존하지만, 익명화 또는 역할 필터링 시 플래그가 설정되지 않으면 전략 작성이 항상 비활성화됩니다.
- 수정: `isMe` 플래그 설정 로직을 백엔드에서 확인하고 폴백 추가.

[M-25] 대시보드 트렌딩 정렬 방향 구분 없음 (Medium)

- 파일: `frontend/src/components/market/AssetList.tsx:127`
- 설명: 트렌딩 탭에서 `Math.abs(changePercent)` 로 정렬하여 -10% 하락과 +10% 상승이 동일 우선순위입니다.
- 수정: 상승/하락을 구분하여 정렬하거나 명확한 정렬 기준 표시.

[L-10] 포트폴리오 도넛 차트 경계 조건 (Low)

- 파일: `frontend/src/components/portfolio/BalanceCard.tsx:58-93`
- 설명: 투자 비율이 0% 또는 100%일 때 SVG 렌더링이 시각적으로 올바른지 확인 필요.

[L-11] 로그인 SMS 모달 닫기 시 세션 미무효화 (Low)

- 파일: `frontend/src/app/(auth)/login/page.tsx:86-90`
- 설명: SMS 인증 모달을 닫을 때 프론트엔드 상태만 초기화하고 백엔드 세션을 무효화하지 않습니다.
- 수정: 모달 닫기 시 세션 무효화 API 호출 추가.

[L-12] 빈 거래 내역 시 시간대별 차트 렌더링 (Low)

- 파일: frontend/src/app/(main)/orders/page.tsx:182-194
- 설명: 거래 내역이 없을 때 maxHourCount 가 1로 설정되어 빈 막대가 모두 100% 높이로 표시됩니다.
- 수정: totalTrades === 0 시 차트를 숨기거나 빈 상태 메시지 표시.

10. 이전 감사 미수정 사항 확인

10차 감사 수정 확인 결과

심각도	건수	주요 범주
Critical	12	데이터 정확성, 보안, 메모리 누수, 주문 실행
High	22	입력 검증, 레이스 컨디션, 정밀도 손실, 인증
Medium	33	성능, 타입 안전성, 캐시 일관성, 접근성
Low	18	i18n, 코드 품질, 예지 케이스, UX
합계	85	
항목	상태	비고
카피 트레이딩 레이스 컨디션	✅ 수정됨	\$transaction + FOR UPDATE 적용
슬리피지 허용	✅ 수정됨	SLIPPAGE_TOLERANCE = 0.02
활동 피드 PII 노출	✅ 수정됨	수량/가격 제거
WebSocket 30초 끊김	✅ 수정됨	ping/pong 핸들러 추가
24H 고가/저가 미갱신	✅ 수정됨	WebSocket에 high24h/low24h 필드 추가
채팅 시스템 메시지 JSON 노출	✅ 수정됨	RoomList에 JSON 파싱 로직 추가
알림 설정 미반영	✅ 수정됨	프론트엔드 필터링 구현

관리자 승인 필터 비활성 포함✅ 수정됨 isActive: true 조건 추가

권고 사항 (Recommendations)

즉시 수정 (Critical — 1-2일 내)

- C-01:** 주문 FILLED 상태 전이 로직 수정
- C-02:** 수량 0 주문 차단
- C-03:** 리더보드 PnL 계산 보정
- C-06:** 회원가입 트랜잭션 원자성 확보
- C-08:** JWT 검증 서킷 브레이커 구현
- C-09:** 타이밍 공격 방지를 위한 토큰 비교 수정

단기 수정 (High — 1주 내)

- H-01:** 자기 거래 방지 로직 추가
- H-03, H-04:** 잔고 정밀도 및 자금 해제 재시도
- H-08~H-11:** SMS 레이트 리미팅, 토큰 갱신 원자성, 관련 데이터 정리
- H-15~H-17:** 프론트엔드 데이터 검증 강화

중기 수정 (Medium — 2주 내)

- 캐시 일관성 및 성능 최적화 (M-04, M-06, M-16)
- 접근성 개선 (M-21, M-23)
- 입력 검증 강화 (M-05, M-12, M-19)

장기 개선 (Low — 백로그)

- i18n 완전성 확보 (L-01, L-06, L-08)
- CSV 이스케이핑, ARIA 속성, 에지 케이스 처리

감사 결론

이번 11차 감사에서는 프로젝트 전체 코드를 파일 단위로 정밀 분석하여 총 **85건**의 이슈를 식별했습니다.

핵심 발견사항:

- 주문 엔진:** FILLED 상태 전이 실패(C-01)는 주문 생명주기의 핵심 결함으로, 즉시 수정이 필요합니다.
 - 데이터 정확성:** 리더보드 PnL 계산(C-03), 캔들스틱 레이스 컨디션(C-04), 부동산수점 정밀도(H-05) 등 금융 데이터의 정확성에 영향을 미치는 이슈가 다수 발견되었습니다.
 - 보안:** RRN 암호화 키 혼용(C-07), 타이밍 공격(C-09), 인증 단일 장애점(C-08) 등 보안 취약점이 있습니다.
 - 프론트엔드:** WebSocket 데이터 파이프라인 개선(10차 대비)이 확인되었으나, 데이터 검증/포맷팅 영역에서 추가 개선이 필요합니다.
- 10차 감사에서 지적된 주요 사항 8건은 모두 수정이 확인되었습니다.

감사 수행: AI 자동 감사 시스템

감사일: 2026-03-10

다음 감사 예정: 전체 수정 완료 후